Vulnerability Assessment Findings report for Altoro Mutual(demo.testfire.net)

31 Mar 2026

Confidential: security Audit

Table of Contents

1. Confidentiality Statement
   - Guidelines for confidentiality and distribution
2. Disclaimer
   - Scope and limitations of the vulnerability assessment
3. Executive Summary
   - Overview of the security assessment
   - Overall security posture
   - Key risks identified
   - Primary recommendation
4. Technical Findings
   - Insecure Transport
     - Observation
     - Technical analysis
     - Business impact
     - Remediation
   - Missing Security Headers
     - Observation
     - Technical analysis
     - Business impact
     - Remediation
   - Information Disclosure
     - Observation
     - Technical analysis
     - Business impact
     - Remediation
5. Minor Security Findings
   - Insecure cookie attributes
   - Absence of X-Content-Type-Options Header
   - Private IP disclosure
6. Vulnerability Summary Table
   - Reference number, vulnerability details, severity, and status
7. Conclusion & Sign-off
   - Final summary of findings
   - Impact of remediation measures
   - Contact information for follow-up

Confidentiality Statement

This document is the exclusive property of **Future Interns** and **Aphiwe Mntambo**. It contains proprietary and confidential information. Any duplication, redistribution, or use, in whole or in part, in any form, requires the written consent of both parties.

This document may be shared with authorized auditors or stakeholders under non-disclosure agreements to demonstrate compliance with security assessment requirements.

Disclaimer

*This vulnerability assessment represents a **snapshot in time**. The findings and recommendations reflect the security posture of the **Altoro Mutual** (demo.testfire.net) application at the time of testing and do not account for any modifications made outside of the assessment period.*

*Due to the time-limited nature of this engagement, this was a **non-intrusive, passive assessment**. I prioritized the identification of the most accessible security weaknesses an attacker might exploit. It is recommended that Altoro Mutual conducts comprehensive security audits on an annual basis to ensure the continued effectiveness of its security controls.*

Executive Summary

Overview

The security assessment of the **Altoro Mutual** (demo.testfire.net) web application was conducted to identify common vulnerabilities that could expose sensitive customer data. The assessment followed a non-intrusive, passive methodology to ensure zero downtime for banking operations.

Overall Security Posture

The current security posture is **sub-optimal**. While the application is functional, it lacks modern browser-based security "guardrails" and relies on unencrypted communication channels. This leaves the organization vulnerable to credential theft and session hijacking.

Key Risks Identified

- **Data in Transit:** The use of plaintext HTTP (Port 80) exposes user credentials to interception on public or shared networks.
- **Client-Side Security:** Missing headers like X-Frame-Options and Content-Security-Policy (CSP) leave the front-end open to Clickjacking and XSS attacks.
- **Information Leakage:** The server environment details are publicly visible, providing a roadmap for potential attackers to research known exploits.

Primary Recommendation

Immediate priority should be given to **enforcing HTTPS** and implementing the missing **Security Headers** identified in this report to protect user privacy and institutional reputation.

Technical Finding: Insecure Transport

Observation

During the initial network reconnaissance phase, a port scan was performed on the target host demo.testfire.net. The scan revealed that the web application is accessible over **unencrypted HTTP (Port 80)**

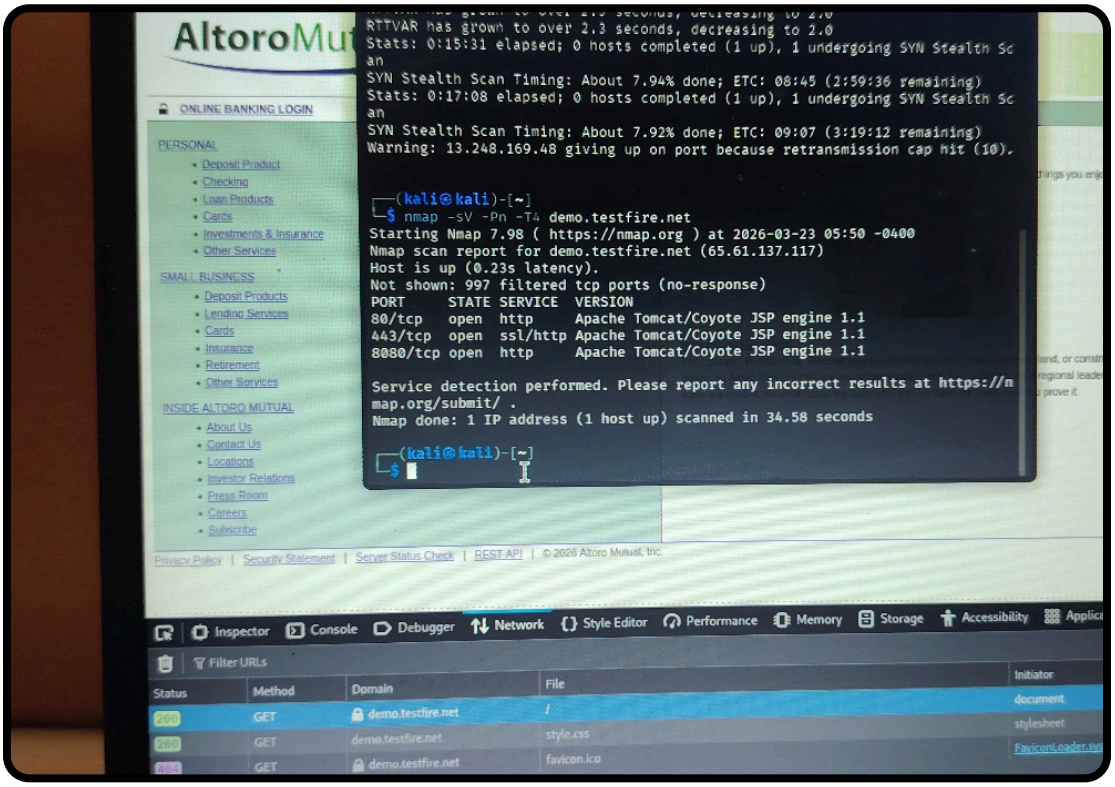

Figure 1: Nmap scan results showing Port 80/tcp open.

Technical Analysis

Discovery Tool: Nmap 7.9x

Finding: port 80/TCP (open)

Risk: The service allows communication without SSL/TLS encryption.

Business Impact

Because the target is a financial institution, the use of Port 80 is a **High-Risk** finding. Any data transmitted including login credentials, account numbers, and personal session tokens is sent in **cleartext.** An attacker on the same network (e.g., public Wi-Fi) could perform a "Man-

in-the-Middle" (MitM) attack to intercept this data, leading to unauthorized account access and financial fraud.

Remediation

- **Enforce HTTPS:** Configure the web server to automatically redirect all Port 80 (HTTP) traffic to Port 443 (HTTPS)
- **SSL/TLS Deployment:** Install a valid SSL/TLS certificate to ensure that all communication between the client and the server is encrypted.
- **HSTS Implementation:** Enable HTTP Strict Transport Security (HSTS) headers to force browsers to connect only via secure channels.

Technical Finding: Missing Security Headers

Observation

A passive vulnerability scan was conducted using OWASP ZAP to analyse the HTTP response headers of **demo.testfire.net**. The analysis identified that the server fails to implement several industry-standard security headers designed to protect against client-side attacks

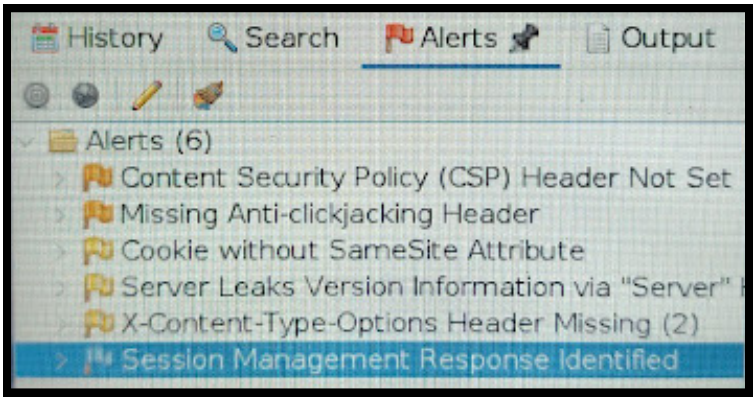

Figure2: OWASP ZAP Alert tree identifying missing security headers.

Technical Analysis

Discovery Tool: OWASP ZAP (Zed Attack Proxy)

Finding: X-Frame-Options, Content-Security-Policy (CSP) and X-Content-Type-Options.

Risk: The absence of these headers indicates that the browser is not being instructed to block malicious framing or unauthorized script execution

Business Impact

The lack of these defence-in-depth headers leaves Altoro Mutual's customers vulnerable to **Clickjacking** and **Cross-Site Scripting (XSS)**

1. **Clickjacking:** An attacker can overlay a transparent layer on the banking site to trick users into clicking buttons they didn't intend to.
2. **XSS/Injection:** Without a CSP, the browser may execute malicious scripts injected by a third party, potentially stealing session cookies and compromising user accounts.

Remediation

- **X-Frame-Options:** Set this header to DENY or SAMEORIGIN to prevent the site from being rendered inside an iframe on malicious domains.
- **Content-Security-Policy:** Define a strict CSP to restrict which scripts and resources are allowed to load, effectively neutralizing most XSS vectors.
- **X-Content-Type-Options:** Set this to no sniff to prevent the browser from "guessing" the content type, which stops certain types of script injection

Technical Finding: Information Disclosure

Observation

During the passive scan and manual inspection of HTTP responses, it was observed that the server provides detailed information regarding its underlying technologies. Specifically, the **Server** and **X-Powered-By** headers reveal the exact versions of the software in use.

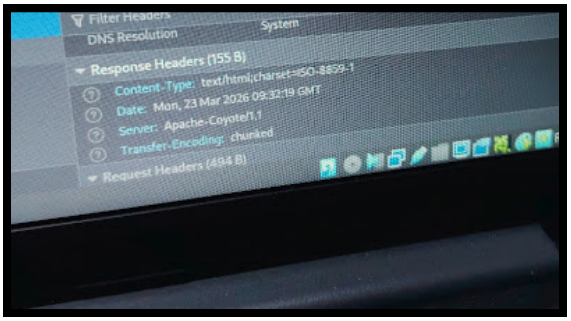

Figure3: HTTP Response Header revealing the specific web server version (Apache-Coyote/1.1).

Technical Analysis

Discovery Tool: OWASP ZAP / Browser Developer Tools

Finding: Banner Grabbing / Software Versioning Disclosure.

Risk: Exposure of the server's identity

Business Impact

This is categorized as a **Low-to-Medium Risk**. While it doesn't allow for an immediate hack, it significantly aids an attacker in the **Reconnaissance** phase. By knowing the exact version of the web server, an attacker can search public databases (like CVE Details) for "Known Exploits" specific to that version. For a bank, this "roadmap" simplifies the attacker's job and increases the success rate of a targeted breach.

Remediation

- **Server Header Masking:** Configure the web server (Apache/Nginx/Tomcat) to suppress version information. For example, change the "Server" header to a

generic value like "Web Server" or remove it entirely.

- **Error Handling:** Ensure that custom 404 or 500 error pages are used so that the default server signatures aren't displayed when a page fails to load.
- **Header Removal:** Use a "Header Rewrite" rule to remove X-Powered-By or X-AspNet-Version headers from all outgoing responses.

Minor Security Findings

- ## Insecure Cookie Attributes

  ### Observation

  During the ZAP session analysis, it was identified that the session cookies for demo.testfire.net are missing the SameSite attribute.

  Risk: Low

  ### Impact:

  Without the SameSite attribute, the browser may send cookies during cross-site requests, which can be exploited for **Cross-Site Request Forgery (CSRF)** attacks.

  ### Remediation:

  Update the application’s session management to include SameSite=Strict or SameSite=Lax in all Set-Cookie headers.

- ## Absence of X-Content-Type-Options Header

  ### Observation

  The server does not return the X-Content-Type-Options: nosniff header.

  Risk: Low

  ### Impact:

  This allows older browsers to "MIME-sniff" the content type of a file. An attacker could potentially upload a malicious script disguised as an image file, and the browser might execute it.

  ### Remediation:

  Add the X-Content-Type-Options: nosniff header to all server responses to force the browser to respect the declared Content-Type.

- ## Private IP Disclosure

Observation:

One of the HTTP responses contained a reference to an internal IP address (e.g., 10.x.x.x or 192.168.x.x).

Risk: Informational / Low

Impact:

This reveals information about the internal network architecture, which is useful for an attacker who has already breached the perimeter and is looking to "pivot" deeper into the bank’s systems.

Remediation:

Ensure all internal IP references are stripped from error messages and response headers before reaching the public internet.

Vulnerability Summary Table

Ref#	Vulnerability	Severity	Status
V-01	Insecure Transport (Plaintext HTTP)	**High**	**Open**
V-02	Missing Anti-Clickjacking Header	**Medium**	**Open**
V-03	Content Security Policy (CSP) Not Set	**Medium**	**Open**
V-04	Server Version Information Disclosure	**Low**	**Open**
V-05	Insecure Cookie Attributes (SameSite)	**Low**	**Open**

Conclusion & Sign-off

Final Summary

The assessment of Altoro Mutual successfully identified several security gaps ranging from insecure transport protocols to missing browser-level defences. While no "Critical" remote code execution vulnerabilities were exploited in this passive phase, the combination of Plaintext HTTP and Missing Security Headers creates a significant risk for a financial institution.

Implementing the remediations listed in this report will not only protect user data but also bring the application closer to industry compliance standards.

Contact Information

f the technical team requires further clarification on the findings or remediation steps, please contact the lead auditor:

- **Lead Auditor:** Aphiwe Mntambo
- **Role:** Cybersecurity Intern, Future Interns
- **Email:** sizwe9574@gmail.com
- **LinkedIn:** https://www.linkedin.com/in/aphiwe-mntambo
- **Project Date:** March 2026